雲端技術及網路服務實務 期末專題

題目：ARP Spoofing 攻擊與防禦研究

成員：113705056 蔡侑呈 happyoyomg.mg13@nycu.edu.tw
113550054 李威慶 smolwei.cs13@nycu.edu.tw
113705007 黃翊婷 qug28.mg13@nycu.edu.tw

繳交時間：2026.01.12

頁數：共 6 頁（含封頁）

摘要內容：本專題以虛擬機環境模擬 ARP Spoofing 攻擊，說明 ARP 協定缺乏認證機制而產生中間人攻擊風險，透過封包擷取與 ARP 表分析觀察流量變化，並實作靜態 ARP 綁定與偵測機制，驗證防禦方法於區域網路中的效果。

I.專案動機

ARP (Address Resolution Protocol) 是區域網路中不可或缺的協定，用於建立 IP 與 MAC 的對應關係。然而 ARP 本身**缺乏認證機制**，任何主機皆可回應 ARP 封包，造成 **ARP Spoofing / ARP Poisoning** 攻擊風險，可能導致 網路中間人攻擊 MITM、封包竊聽、流量導向惡意節點 等問題，所以我們想自建 VM 模擬 **ARP Spoofing** 的效果及防禦方法。

***ARP Spoofing** : 一種攻擊技術，攻擊者可取的區域網路上的資料封包，甚至竊取封包，且可讓電腦無法正常連線。

II. 實驗說明

架構：

同二層網　　段設置三台虛擬主機

- VM-A ：攻擊者
- VM-B ：受害者
- Router ：網關，轉送至外網

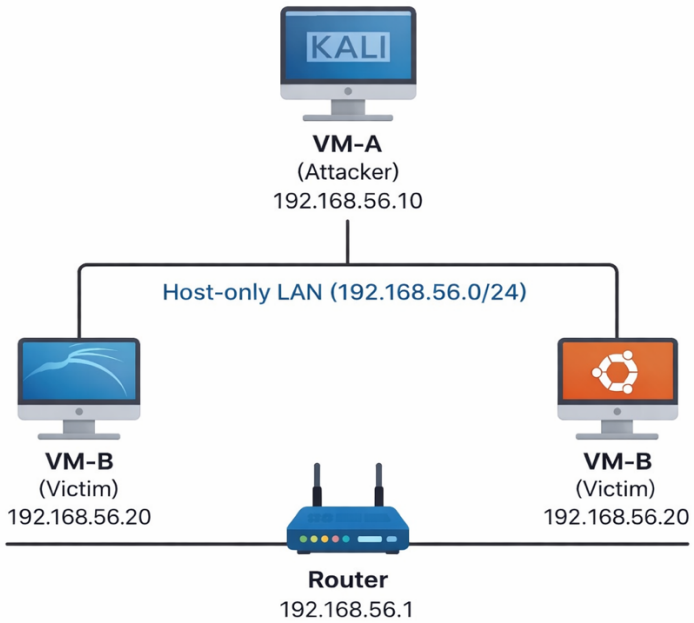


圖 1 實驗拓樸示意圖：三台虛擬機位於同一個二層網段網段，VM-A 為攻擊者，VM-B 為受害者，Router 作為預設網關。

實驗流程：

A. 建立正常通信環境

B. 觀測正常 ARP Request & Reply

C. 攻擊者發送偽造 ARP Reply -> 污染 ARP Cache

D. 流量導入攻擊者-> MITM 成立

E. 防禦措施

1. 靜態 ARP 綁定 -> Cache 不再變動

2. 偵測 arpwatch / ip monitor
3. 補充 DAI 、Switch ACL 等解法

III. 實驗操作過程

一、建立正常網路環境

```
happyoyomg@victim:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: enp0s8: <BROADCAST,MULTICAST> mtu 1500 qdisc fq_codel state DOWN group default qlen 1000
    link/ether 08:00:27:55:58:be brd ff:ff:ff:ff:ff:ff
3: enp0s9: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default
 qlen 1000
    link/ether 08:00:27:9d:c1:da brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.3/24 brd 192.168.56.255 scope global dynamic noprefixroute enp0s9
       valid_lft 2567sec preferred_lft 2567sec
happyoyomg@victim:~$ ip route
default via 192.168.56.1 dev enp0s9
172.17.0.0/16 dev docker0 proto kernel scope link src 172.17.0.1 linkdown
172.18.0.0/16 dev br-b21a4e0dc0e0 proto kernel scope link src 172.18.0.1 linkdown
172.19.0.0/16 dev docker_gwbridge proto kernel scope link src 172.19.0.1
192.168.56.0/24 dev enp0s9 proto kernel scope link src 192.168.56.3 metric 101
```

設定 router（代表網關/外網出口）

sudo ip addr add 192.168.56.1/24 dev enp0s8
sudo ip link set enp0s8 up

設定 VM-B（會被導流量）

sudo ip addr add 192.168.56.20/24 dev enp0s8
sudo ip link set enp0s8 up
sudo ip route add default via 192.168.56.1

設定 VM-A（負責偽造 ARP）

sudo ip addr add 192.168.56.10/24 dev enp0s8
sudo ip link set enp0s8 up
sudo ip route add default via 192.168.56.1

安裝 Wireshark 並啟動

正常狀態下 VM-B 的 ARP 表

```
happyoyomg@victim:~$ ip neigh
192.168.56.1 dev enp0s9 lladdr 9e:58:84:02:cd:64 REACHABLE
192.168.56.4 dev enp0s9 lladdr 08:00:27:7d:84:71 REACHABLE
192.168.56.2 dev enp0s9 lladdr 08:00:27:d3:6f:2b REACHABLE
fe80::9c58:84ff:fe02:cd64 dev enp0s9 lladdr 9e:58:84:02:cd:64 router STALE
```

在未進行任何攻擊前，VM-B 透過 ARP 協定學習 Gateway（192.168.56.1）之 MAC 位址。圖中可觀察到 Gateway 的 IP–MAC 對應為動態學習狀態（如 REACHABLE / STALE），顯示 ARP 在正常網路環境下可正確運作，作為後續攻擊與防禦實驗之基準狀態（baseline）。

正常狀態下之 ARP Request 封包（Wireshark）

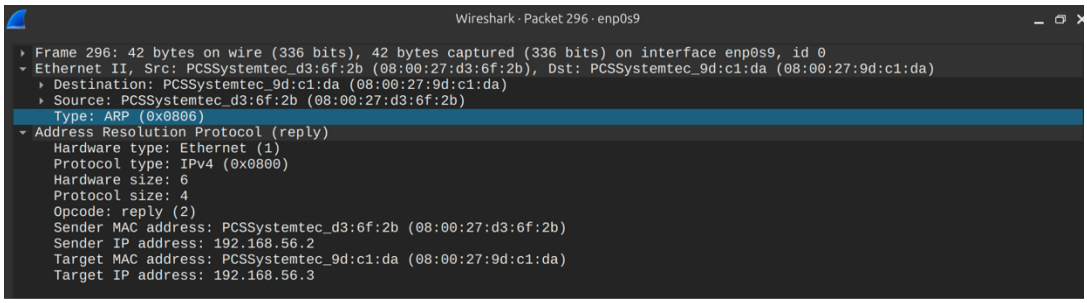
當 VM-B 欲與 Gateway 通訊時，會於同一個二層網段中廣播 ARP Request，詢問 Gateway（192.168.56.1）對應的 MAC 位址。該封包顯示 ARP Request 為廣播封包（Broadcast），為 ARP 協定在區域網路中解析 IP–MAC 對應關係的正常行為。

二、ARP Spoofing

VM-A 不停丟偽造 ARP reply

-> VM-B 把 Router MAC 設成攻擊者的 MAC

原本給 Router 的封包被改送到 VM-A



ARP 協定本身缺乏驗證與認證機制，
任一主機皆可送出 ARP Reply 封包宣稱自身為特定 IP 位址。
一旦受害主機接受錯誤的 ARP 回應，其 ARP Cache 可能遭到污染，
導致流量被轉送至非預期之主機，形成中間人攻擊（MITM）風險。

三、攻擊造成的危害示範

wireshark 看到封包被轉送到 VM-A

```
happyoyomg@victim:~$ ip neigh show 192.168.56.1
192.168.56.1 dev enp0s9 lladdr 9e:58:84:02:cd:64 STALE
happyoyomg@victim:~$ sudo ip neigh replace 192.168.56.1 lladdr 9e:58:84:02:cd:64 nud perman
ent dev enp0s9
[sudo] password for happyoyomg:
happyoyomg@victim:~$ ip neigh show 192.168.56.1
192.168.56.1 dev enp0s9 lladdr 9e:58:84:02:cd:64 PERMANENT
```

於未啟用防禦機制時，可觀察到 VM-B 的 ARP 表中，
Gateway（192.168.56.1）之 IP–MAC 對應可能出現異常變動，
顯示 ARP 協定缺乏認證機制，存在遭中間人攻擊（MITM）之風險。

四、防禦測試

VM-B 靜態 ARP 綁定：PERMANENT 使 ARP Cache 不再變動

```
happyoyomg@victim:~$ sudo ip neigh replace 192.168.56.1 lladdr 08:00:27:7d:84:71
 nud permanent dev enp0s8
happyoyomg@victim:~$ ip neigh show 192.168.56.1
192.168.56.1 dev enp0s8 lladdr 08:00:27:7d:84:71 PERMANENT
192.168.56.1 dev enp0s9 lladdr 08:00:27:7d:84:71 STALE
```

偵測：

VM-B 裝 **ip monitor**

只要 ARP 一變動 就會跳訊息

```
happyoyomg@victim:~$ ip monitor neigh
192.168.56.4 dev enp0s9 lladdr 08:00:27:7d:84:71 STALE
192.168.56.1 dev enp0s9 lladdr 08:00:27:7d:84:71 STALE
192.168.56.4 dev enp0s9 lladdr 08:00:27:7d:84:71 PROBE
192.168.56.4 dev enp0s9 lladdr 08:00:27:7d:84:71 REACHABLE
192.168.56.1 dev enp0s9 lladdr 08:00:27:7d:84:71 PROBE
192.168.56.1 dev enp0s9 lladdr 08:00:27:7d:84:71 REACHABLE
dev veth4f6dbf9 lladdr 42:18:8c:2d:3b:fb PERMANENT
dev veth4f6dbf9 lladdr 42:18:8c:2d:3b:fb PERMANENT
dev veth4f6dbf9 lladdr 02:c4:37:b2:de:c8 REACHABLE
192.168.56.1 dev enp0s9 lladdr 08:00:27:7d:84:71 STALE
Deleted dev veth4f6dbf9 lladdr 02:c4:37:b2:de:c8 REACHABLE
Deleted ff02::fb dev veth4f6dbf9 lladdr 33:33:00:00:00:fb NOARP
Deleted ff02::2 dev veth4f6dbf9 lladdr 33:33:00:00:00:02 NOARP
Deleted ff02::1:ff2d:3bfb dev veth4f6dbf9 lladdr 33:33:ff:2d:3b:fb NOARP
Deleted ff02::16 dev veth4f6dbf9 lladdr 33:33:00:00:00:16 NOARP
Deleted ff02::16 dev br-b21a4e0dc0e0 lladdr 33:33:00:00:00:16 NOARP
Deleted dev veth4f6dbf9 lladdr 42:18:8c:2d:3b:fb PERMANENT
Deleted dev veth4f6dbf9 lladdr 42:18:8c:2d:3b:fb PERMANENT
192.168.56.4 dev enp0s9 lladdr 08:00:27:7d:84:71 STALE
192.168.56.4 dev enp0s9 lladdr 08:00:27:7d:84:71 PROBE
192.168.56.4 dev enp0s9 lladdr 08:00:27:7d:84:71 REACHABLE
```

這就是網管在抓 ARP spoofing 的方式之一

IV. 遭遇困難與解決方式

在本次 ARP Spoofing 相關實驗過程中，初期遇到多項操作與理解上的困難，主要原因並非工具使用問題，而是對網路行為與環境設定的掌握不足。以下說明實驗中遭遇的主要問題及對應之解決方式。

一、Wireshark 無法抓取預期的 ARP 封包

在實驗初期，使用 Wireshark 進行封包擷取時，無法觀察到預期之 ARP Request 與 Reply 封包，所擷取到的封包內容與實驗設定的 Host-only 網段不一致，導致無法進行後續分析。

經檢查後發現，虛擬機同時啟用了 NAT 與 Host-only 兩張網路介面，Wireshark 初期選擇錯誤的介面進行擷取，導致所觀察到的封包實際來自 NAT 網段，而非實驗所需的區域網路。修正擷取介面為 Host-only 網卡後，方能正確觀察 ARP 封包行為。

二、預設閘道設定錯誤影響 ARP 行為

即使修正擷取介面後，仍觀察到主機向非預期之 IP 位址發送 ARP Request，導致實驗結果與原先設計之網路拓樸不一致。

進一步檢查路由表後發現，受害主機之預設閘道仍指向 NAT 網段的 gateway，而非 Host-only 網段之 Router。由於 ARP 行為與路由設定密切相關，錯誤的預設閘道會導致主機查詢錯誤的 IP 位址。修正預設閘道設定後，ARP 行為即與實驗拓樸一致。

三、靜態 ARP 防禦設定與驗證

為驗證防禦機制之有效性，於受害主機上設定靜態 ARP 綁定，將 Gateway 的 IP－MAC 對應設為永久（PERMANENT）。設定完成後，ARP cache 不再因動態 ARP 封包而更新，成功防止 ARP Spoofing 類型之攻擊。

透過防禦前後之比較，確認靜態 ARP 綁定能有效降低 ARP 協定缺乏驗證所帶來的安全風險。

V. 結論與心得

本實驗成功展示了 ARP 缺乏認證機制而容易遭受 Spoofing，導致中間人攻擊（MITM）。

我們也透過靜態 ARP 綁定驗證了防禦方式的有效性，顯示端點安全對區域網路的重要性。